

Change Management Compensating Control Policy

Policy Owner: Chief Technology Officer

Effective Date: 2026-08-16

Review Cadence: Revisit immediately upon hiring a second engineer, or annually, whichever comes first.

Purpose

SOC 2 CC8.1 and CC5.2 expect that changes to production systems are reviewed by someone other than the person who made them before those changes merge. This policy documents why DeepFeat, Inc. cannot satisfy that expectation through unassisted human review alone, and defines the specific compensating control the company uses instead.

The constraint

DeepFeat, Inc. has one engineer (the CTO). The Chief Executive Officer, Matthew Bockelmann, does not have an engineering background and cannot meaningfully evaluate source code for correctness. Requiring a second engineer's approval on every pull request is not achievable at this stage without either hiring an additional engineer or creating a bottleneck that would, in practice, get worked around — a worse outcome than a properly documented and monitored compensating control.

This is a structural limitation of company size, not a gap in intent or process discipline.

Why this control matters

A SOC 2 Type II audit samples change records across the observation window and checks each one for an approver who was not the change's author. A single self-merged pull request with no recorded approver, found in that sample, is a real exception against a critical control — regardless of the overall quality or intent of the company's engineering practice. The control described below exists specifically to close that gap.

The compensating control

DeepFeat, Inc. implements a two-part compensating control, effective 2026-08-16:

Automated review on every pull request

An AI-based review system (Claude, via the DeepFeat/pr-governance shared workflow) reviews every pull request against the target repository's stated engineering conventions, checking for defects, security issues, and missing test coverage. The system submits a **formal GitHub pull request review** — an approval or a request for changes — not merely a comment.

This is a deliberate and disclosed design choice: an automated system is the entity satisfying the “approving review” requirement on most pull requests. It closes the *sampling* risk described above — every change has a recorded, non-author approver — but it does not substitute for human judgment about business risk. That is the purpose of the monthly human review described next.

This control is enforced technically, not only by convention: an organization-wide GitHub branch protection ruleset requires at least one approving review on every pull request to every DeepFeat, Inc. repository, with **no bypass permitted for any user, including administrators**.

Monthly human review of material changes

Pull requests touching authentication, access control, data handling, or infrastructure are automatically labeled security-relevant. Once each month, a summary of all such changes merged in the preceding period is compiled and assigned to the Chief Executive Officer for review.

This review is conducted at the level of business risk — confirming the CEO understands what changed, why, and that it is consistent with DeepFeat, Inc.'s obligations to its customers — rather than a technical correctness review, which is outside the CEO's domain of expertise. The CEO records sign-off in writing on each monthly review; that written record is retained as the audit evidence for this control.

Scope

This policy applies to all repositories owned by the DeepFeat, Inc. GitHub organization.

Historical exception

Pull requests merged before 2026-08-16 were merged without a second reviewer, by necessity: no compensating control existed prior to this policy's effective date, and no second technical reviewer was available. This is documented as a dated, bounded exception. All pull requests merged on or after 2026-08-16 are subject to the controls described above without exception.

Revision trigger

Upon DeepFeat, Inc. hiring a second engineer, the automated review's approval should be downgraded from an approving reviewer to a required status check, and a genuine second engineer's review should become the approving reviewer of record. This policy must be revised at that time.

Cross-references

- Implementation: DeepFeat/pr-governance — review.yml, auto-label.yml, monthly-retro.yml
- Organization-wide branch protection: GitHub organization ruleset "Org-Level SOC 2 Protect Main"